

General Data Protection Regulation

Yvette Graham, ygraham@tcd.ie

Thanks to: Dave Lewis, Harsh Pandit, Kaniz Fatema, Irish Data Protection Commission



Two Different Perspectives

Part 1: Individual Perspective

Part 2: Organizational Perspective



Objectives

Part 1: Individual Perspective

- The aims of the General Data Protection Regulation (GDPR)
- GDPR Principles
- Individual Perspective: Your rights under GDPR



The Fundamental Right of Data Protection

Data protection is a fundamental right set out in Article 8 of the **EU Charter of Fundamental Rights**, which states:

- Everyone has the right to the protection of personal data concerning him or her.
- Such data must be processed fairly for specified purposes and on the basis of the consent of the person concerned or some other legitimate basis laid down by law. Everyone has the right of access to data which has been collected concerning him or her, and the right to have it rectified.
- Compliance with these rules shall be subject to control by an independent authority.

General Data Protection Regulation

- The General Data Protection Regulation (GDPR) came into force on 25 May 2018.
- General application to the processing of personal data in the EU
- Sets out extensive obligations on data controllers and processors and provides strengthened protections for data subjects.
- GDPR is directly applicable as a law in all EU Member States
- Certain issues have further effect in national law.
 - In Ireland, this is the Data Protection Act 2018.

Key Roles in GDPR

- Data Subject: any person **whose personal data** is being collected, held or processed.
- Data Controller: A person, company, or other body which **decides** the purposes and methods of processing personal data.
- Data Processor: A person, company, or other body which processes personal data **on behalf** of a data controller.
- Controllers and Processors are **accountable** for processing of personal data to Supervisory Authority

Key Roles in GDPR: Supervisory Authority

- Supervisory Authority: Independent public authorities responsible for monitoring the application of GDPR in a member state
- In Ireland the Supervisory Authority is the Data Protection Commission
- The Commission is responsible for **monitoring** the application of the GDPR in order to **protect the rights and freedoms** of individuals in relation to processing.
- Commission role includes: promoting public awareness of risks/rules/safeguards/rights; handling data subject complaints; and cooperating with other data protection authorities in other EU member states.
- Violators of GDPR may be fined up to €20 million, or up to **4% of the annual worldwide turnover** of the preceding financial year, whichever is greater



What is Personal Data?

The term 'personal data' means any information concerning or relating to a **living person who is either identified or identifiable** (i.e. the 'data subject').

An individual could be identified, **directly or indirectly**, in particular by reference to an identifier such as a

- name, an identification number, location data, an online identifier (such as an IP address) or
- to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that individual.



Special categories of personal data

Certain types of sensitive personal data are subject to additional protection under the GDPR. The special categories are:

- Personal data revealing racial or ethnic origin
- Political opinions
- Religious or philosophical beliefs
- Trade union membership
- Genetic data and biometric data processed for the purpose of uniquely identifying a natural person
- Data concerning health
- Data concerning a natural person's sex life or sexual orientation



What is Data Processing?

The term “processing” refers to any operation or set of operations performed on personal data.

- Processing includes
 - storing,
 - collecting,
 - retrieving,
 - using,
 - combining,
 - erasing and
 - destroying personal data.
- Processing can involve automated or manual operations.



Principles for Personal Data Processing

Personal data shall be:

- Processed **lawfully, fairly and in a transparent** manner;
- Collected for specified, explicit and legitimate **purposes** and not further processed in a manner that is incompatible with those purposes; ('purpose limitation');
- **Adequate, relevant and limited** to what is necessary in relation to the purposes for which they are processed ('data minimisation');
- **Accurate** and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate are erased or rectified without delay ('accuracy');
- Kept in a form which permits identification of data subjects for **no longer than is necessary** for the purposes for which the personal data are processed; ('storage limitation');
- Processed in a manner that ensures appropriate **security** of the personal data, ('integrity and confidentiality').



Lawful Basis for Personal Data Processing

Article 6 of the GDPR sets out the complete list of lawful reasons for processing personal data as:

1. **Consent.**
2. To carry out a **contract**.
3. In order for an organisation to meet a **legal obligation**.
4. Where processing the personal data is necessary to protect the **vital interests of a person**.
5. Where processing the personal data is necessary for the performance of a task carried out in the **public interest**.
6. In the **legitimate interests** of a company/organisation (except where those interests contradict or harm the interests or rights and freedoms of the individual)

Consent

- Some types of processing are carried out on the basis that you have given your consent.
 - Under the GDPR, consent to processing must be
 - freely given,
 - specific, and
 - informed.
- 
- You cannot be forced to give your consent,
 - You must be told what purpose(s) your data will be used for
 - You should show your consent through a 'statement or as a clear affirmative action' (e.g. ticking a box).

Rights under GDPR

Right of:

- Access
- To be Informed
- Rectification
- Erasure ('to be forgotten')
- Portability
- Informed about automated decision making
- To object to processing



Right of Access

You have the right to obtain the following:

- **Confirmation** of whether or not personal data concerning you is being processed.
- Where personal data concerning you is being processed, **a copy** of your personal data.
- Where personal data concerning you is being processed, other **additional information** as follows:
 - Purpose(s) of the processing.
 - Categories of personal data.
 - Any recipient(s) of the personal data to whom the personal data has or will be disclosed, in particular recipients in third countries or international organisations and information about appropriate safeguards.
 - The retention period or, if that is not possible, the criteria used to determine the retention period
 - The existence of rights to: rectification; erasure; restrict processing; object; and how to request these from the controller.
 - The right to raise a concern with a supervisory authority (in Ireland this is the Data Protection Commission).
 - Where personal data is not collected from the data subject, any available information as to its source.
 - The existence of automated decision-making, including profiling and meaningful information about how decisions are made, the significance and the consequences of processing.



Right to be Informed

- It should be **clear and transparent** to individuals that personal data concerning them are collected, used, consulted or otherwise processed, and to what extent the personal data are, or will be, processed.
- The principle of transparency: any information on the processing of personal data must be
 - Easily accessible 
 - Easy to understand,
 - In clear and plain language – including visualisations
- Individuals should be **made aware of** risks, rules, safeguards and rights in relation to the processing of personal data.
- In particular, the **specific purposes** for which personal data are processed should be explicit and legitimate and determined at the time of the collection of the personal data.

Right to Rectification

If your personal data is inaccurate, you have the right to have the **data rectified**, by the controller, without undue delay.

If your personal data is incomplete, you have the right to have **data completed**, including by means of providing supplementary information.

The right of rectification is **restricted** for important objectives of public interest, and for balance with the right of freedom of expression and information.

Right to Erasure (a.k.a. Right to be Forgotten)

You have the right to have your data erased by the data controller, if one of the following grounds applies:

- Where your personal data is **no longer necessary in relation to the purpose** for which it was collected or processed.
- Where you **withdraw your consent** to the processing and there is no other lawful basis for processing the data.
- Where you **object to the processing and there is no overriding legitimate grounds** for continuing the processing or your personal data is being processed for direct marketing purposes.
- Where your personal data has been **unlawfully processed**.
- Where your personal data has to be erased in order to comply with **a legal obligation**.
- Where your personal data has been collected in relation to the offer of information society services (e.g. social media) to a child.

The data controller must **communicate any rectification or erasure to each recipient** to whom the personal data has been disclosed, and inform you about recipients if requested

Exception where processing is necessary for:

- Exercising the right of freedom of expression and information.
- Compliance with a legal obligation, the performance of a task carried out in the public interest or in the exercise of official authority.
- Reasons of public interest in the area of **public health**, of **archiving** in the public interest, of **scientific or historical research** purposes or **statistical purposes**.
- Establishment, exercise, or defense **of legal claims**.



Right to Portability

In some circumstances, you may be entitled to obtain your personal data from a data controller in a **format that makes it easier to reuse** your information in another context, and to transmit this data to another data controller of your choosing without hindrance.

This right only applies where processing of personal data is carried out by automated means, and where you have either consented to processing, or where processing is conducted on the basis of a contract between you and the data controller.

This right only applies to the extent that it **does not affect the rights and freedoms of others.**

Where this right applies, data controllers must provide and transmit personal data in **structured, commonly used and machine-readable form.**

Rights on Automated Decision Making

You have the right **not to be subject** to a decision based **solely on automated processing**. Processing is “automated” where it is carried out without human intervention and where it produces legal effects or significantly affects you.

Automated processing includes profiling. Profiling is any kind of automated processing of personal data that involves **analysing or predicting your behaviour, habits or interests**.

Automated processing is permitted only

- with your express consent,
- when necessary for the performance of a contract or
- when authorized by Union or Member State law.



Where one of these exceptions applies, suitable measures must be in place to safeguard your rights, freedoms and legitimate interests. This may include

- the right to **obtain human intervention** on the controller’s part,
- the right to **present your point of view**, and
- the right to **challenge the decision**.

Right to Object to Processing

You have the right to object to certain types of processing of your personal data where this processing is carried out in connection with tasks:

- in the public interest,
- under official authority, or
- in the legitimate interests of others.



You have a stronger right to object to processing of your personal data at any time where the processing relates to **direct marketing**.

You may also object to processing of your personal data for **research purposes**, unless the processing is necessary for the performance of a task carried out in the public interest.

Where the right to object applies, data controllers are obliged to notify you of this at the time of their first communication with you. Where processing is carried out online, data controllers must offer an online method to object.

Right to Restriction

You have a **limited right of restriction** of processing of your personal data by a data controller.

Where processing of your data is restricted, it can be stored by the data controller, but most other processing actions, such as deletion, will require your permission.

This right applies in four ways.

- where you have **objected to processing** of your data
- where you have **contested the accuracy** of your data
- where processing is **unlawful**.
- where you require data for the **purpose of a legal claim**.



Where you have obtained restriction of processing of your data, the data controller must inform you before lifting the restriction.

Limitations on Individual Rights

- The right to data protection is **not an absolute right**.
- It must always be balanced against other values, fundamental rights, human rights, or public and private interests.
 - For example, your right to access your data should not adversely affect the rights and freedoms of **others**.
- In limited circumstances, organisations, may **charge a reasonable fee** for responding to a request, or even to refuse to respond if it is manifestly unfounded or excessive.
- Organisation must always respond to your requests within **one month**, even if they plan to refuse it.
- If refusing a request, an organisation must set out clearly which limitation or restriction they are relying, their reasons for for doing so, and the possibility of lodging a complaint.

Complaining to Supervisory Authority

There are three types of access request complaints:

- **No response** to an access request.
- **Incomplete** response to an access request.
- Exemptions to withhold data being **applied incorrectly**.

For example, if you believe a data controller has not responded in full to your access request, provide the DPC:



- A copy of the access request.
- Signed authority from you where a solicitor/representative has made the contact.
- A copy of any letter sent to the data controller outlining the specific personal data that has not been provided.
- Any evidence you have of the existence of the personal data concerned.
- Any other relevant correspondence on the matter.
- Exemptions being used to withhold data that may be applied incorrectly

Part 2: Organizational Perspective

Objectives

- Organizational Perspective and Issues
- Privacy Canvas Exercise
- Ethical vs Privacy concerns



Principles of Data Protection – Data Controllers

GDPR sets out seven key principles related to the processing of personal data,

- Lawfulness, fairness, and transparency;
- Purpose limitation;
- Data minimisation;
- Accuracy;
- Storage limitation;
- Integrity and confidentiality; and
- Accountability.



Controllers need to be **aware of and comply with** these principles when collecting and otherwise processing personal Data.

Accountability Obligation

Organisations, and not data protection authorities, must **demonstrate** that they are compliant with the law.

Relevant measures include:

- Adequate **documentation** on what personal data is processed;
- How, to what purpose, and how long data will be processed for;
- Documented processes and procedures aiming at tackling data protection issues at an **early stage** when building information systems or **responding to a data breach**; and
- The presence of a **Data Protection Officer** (if required) who is integrated in the organisation planning and operations etc.

Make **an inventory of all personal data** you hold and examine it under the following headings:

- Why are you holding it?
- How did you obtain it?
- Why was it originally gathered?
- How long will you retain it?
- How secure is it, both in terms of encryption and accessibility?
- Do you ever share it with third parties and on what basis might you do so?



Transparency Obligations

Businesses and organisations that process personal data must **provide individuals with information** on the type of processing that is taking place and who is carrying it out.

At a minimum, this information must clearly state:

- Who you (the organisation) are.
- Why you are processing the data.
- What legal basis you rely on to legitimise the processing.
- Whether or not the data will be transferred on to other organisations or individuals.
- How long the data will be stored.
- The existence of the individual's rights under data protection, including the rights to access, correction, erasure, restriction, objection and portability.



Personal Data Breach Obligations

A **personal data breach** means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data

Personal data breaches can be the result of both

- **accidents** (such as sending an email to the wrong recipient) as well as
- **deliberate acts** (such as phishing attacks to gain access to customer data).



A personal data breach negatively impacts the **confidentiality, integrity, or availability** of personal data;

It means that the controller is **unable to ensure compliance** with the principles relating to the processing of personal data under GDPR.

There are two primary obligations on controllers under GDPR:

- **notification of any personal data breach to the DPC**, unless they can demonstrate it is unlikely to result in a risk to data subjects; and
- **communication of that breach to data subjects**, where the breach is likely to result in a high risk to data subjects.

In general terms, a natural person can be considered as **“identified”** when, within a group of persons, he or she is "distinguished" from all other members of the group.

- Accordingly, the natural person is **“identifiable”** when, although the person has not been identified yet, it is possible to do it...



- “Singling out” is when it is possible to distinguish the data relating to one individual from all other information in a dataset.
- For example, there might be only one individual in a dataset who is 160cm tall and was born in 1990, even though there are many others who share either the height or year of birth.

Anonymisation and Pseudoanonymisation: What?

Data can be considered “**anonymised**” from a data protection perspective when data subjects are not identified or identifiable, having regard to all methods reasonably likely to be used by the data controller or any other person to identify the data subject, directly or indirectly.

Irreversibly and effectively anonymised data is not “personal data” and not subject to GDPR



If the source data is not deleted at the same time that the ‘anonymised’ data is prepared, where the source data could be used to identify an individual from the ‘anonymised’ data, the data may be considered only ‘**pseudonymised**’ and thus still ‘personal data’, therefore still subject to.

N.B. It is **not** normally possible to **quantify the likelihood of re-identification** of individuals from anonymised data

Anonymisation and Pseudoanonymisation: Why?

Anonymisation and Pseudoanonymisation can be used

1. To improve protection for data subjects.
2. As part of a risk minimisation strategy when sharing data with data processors or other data controllers.
3. To avoid inadvertent data breaches occurring when your staff is accessing personal data.
4. As part of a “data minimisation” strategy aimed at minimising the risks of a data breach for data subjects.



Data Linking

Any linking of identifiers in a data set will make it more likely that an individual is identifiable.

For example, taken individually the first and second name “John” and “Smith” might not be capable of distinguishing one of a large company’s customers from all other customers, but if the two pieces of information are linked, it is far more likely that “John Smith” will refer to a unique, identifiable individual.

Re-identification from Data Linking

A major risk factor which may lead to the identification of individuals from anonymised data is the **risk of data from one or more other sources being combined or matched** with the anonymised data.

Source of matching data

- **Public registers**, such as the Land Registry, Register of Electors, or publicly accessible registries of the members of professions.
- **Searchable information** contained on the internet or in online databases. e.g. newspaper stories, blog posts or online directories, or data published in previous data breaches.
- **Statistical data** published in an anonymised format, which might be combined with certain anonymised data to identify a data subject. This is a particular concern in the case of research or statistical publications concerning the same data subjects. Information available to the particular organisation or individual that is being given access to anonymised data, e.g Yahoo search log dataset
- **Personal knowledge**

Data minimisation and collection techniques, which are also part of the principles of data protection are helpful in reducing the risk of data matching being successful



Privacy by Design and by Default

Data Protection by design means embedding data privacy features and data privacy enhancing technologies directly into the design of projects at an early stage. This will help to ensure better and more cost-effective protection for individual data privacy.

Data Protection by default means that the user service settings (e.g. no automatic opt-ins on customer account pages) must be automatically data protection friendly, and that only data which is necessary for each specific purpose of the processing should be gathered at all.

Ethics Canvas

Ethics Canvas Project Title:			Date:	
Individuals affected- 1: Who uses the application? Who is affected by its use? What are their gender, age etc?	Behaviour - 3: How might people's behavior change due to the application, e.g. in habits, time-schedule, choice of activities?	What can we do? 9 : What are the most important ethical impacts and how can you mitigate these?	Worldviews - 5: How might people's worldview be affected by the application, e.g. o consumption, religion, work etc?	Groups affected – 2: Which groups are affected by the application, e.g. work-related, interest or advocacy groups?
	Relations - 4: How do relations between individuals and groups change, e.g. between friends, family, co-workers etc?		Group Conflicts - 6: How might group conflicts arise or be affected by the application. E.g. in discrimination, loss of work etc?	
Product or Service Failure – 7: What types of failures could the application experience and what would the impact of these?			Use of Resources – 8: What resources does the application consume and what is the impact of that consumption?	



The Ethics Canvas is adapted from Alex Osterwalder's Business Model Canvas. The Business Model Canvas is designed by: Business Model Foundry AG. This work is licensed under the Creative Commons Attribution-Share Alike 3.0 unported license. To view a copy of this license, visit <https://creativecommons.org/licenses/by-sa/3.0/>. To view the original Business Model Canvas, visit <https://strategyzer.com/canvas>.

Ethics Canvas v1.8 - ethicscanvas.org © ADAPT Centre
 The ADAPT Centre for Digital Content Technology is funded under the SFI Research Centres Programme (Grant 13/RC/2106) and is co-funded under the European Regional Development Fund. .



Data Protection Canvas

Data Protection Canvas Project Title:			Date:	
Data Subjects- 1: What type of people do you hold personal data on? Employees/Customers Adults/ Children Etc?	Purpose - 3: For what purposes are data being collected?	Risk Mitigation? 9 : What measures need to be put in place to reduce the risks of GDPR non-compliance?	Transparency - 5: Is there transparency in the processing and use of the data? I.e: Info notices, paper trails etc	Data Types – 2: What type of data do you hold? Children data? Sensitive data? Biometric data(data that could identify a person)?
	Consent - 4: Has consent been asked for data collection or will it be asked? Is it presented clearly? Is consent revocable?		Rights- 6: Can data subjects access their data on request? Can the data be erased? Can data subjects object to certain types of use of the data eg: direct marketing? Will data subjects be notified on a data breach?	
Storage – 7: Is there a storage time limitation? What technical measures have been taken to protect personal data from un-authorised access? What level of security is needed?			Breach – 8: What happens after a data breach? Who is notified? Do you maintain an internal breach register? Possibility of administration fines	

